Grafeat Meta Permission Audit

Evidence-based review of all 14 permissions/features on the current App Review screen, prepared ahead of Grafeat's first Meta App Review submission for Brener Digital LLC. Read-only audit — no code, OAuth configuration, or Meta settings were changed in producing this.

Prepared: 2026-10-30 **Scope:** 14 listed permissions + automated-engagement feasibility research

Status key: CONFIRMED codebase/test fact DECISION architectural decision (docs/DECISIONS.md) FLAG

Summary · A. Permission table · B. Minimum set · C. Defer list · D. Missing permissions · E. Pre-review prerequisites · F. Uncertainties · Automated likes/comments research

Summary

Of the 14 items on the App Review screen, **7 are on the Facebook Login for Business track and are the ones the shipped product actually depends on** — these should form the minimum request. **4 belong to the Instagram Login track**, which is fully implemented and tested but explicitly *not* used by the production discovery/processing pipeline (confirmed in `docs/HANDOVER.md` §4) — kept only as a development-only alternative connection. **3 have no implementation, no code reference anywhere in this repository, and no planned feature that would use them.**

The single most important item is **Instagram Public Content Access** (#14) — the entire hashtag-discovery mechanism depends on it, and it carries a genuine, unresolved contradiction in this project's own history that needs direct clarification before submission (see F).

> **On "KEEP / REMOVE / DEFER / INVESTIGATE" below:** these describe whether to *request Advanced Access for this App Review round* — not whether to delete any connect-flow code. Grafeat's Instagram Login connect flow, for example, stays in the codebase either way; the recommendation is only about what to ask Meta to review right now.

A. Complete 14-row permission audit

`01` **`instagram_business_basic`** DEFER

Instagram Login only

PURPOSE	Base read access to the connected Instagram professional account's own profile/media — the foundation scope for the Instagram Login connect flow, used to fetch the connected account's `id` / `username` for display.
AUTH PATH	Instagram Login only.

STATUS	`CONFIRMED` Implemented and tested — connect/callback flow works, confirmed live PASS in `SPIKE-RESULTS.md` §1a. `CONFIRMED` Not used by the production pipeline — `docs/HANDOVER.md` §4 states the Instagram Login connection is "not used anywhere in the Slice B pipeline," kept only as the "Advanced: Instagram Login (development)" dashboard option.
API DEPENDENCY	`GET graph.instagram.com/v21.0/me?fields=id,username` — `app/api/auth/instagram/callback/route.ts`.
EVIDENCE	`app/api/auth/instagram/start/route.ts` (SCOPES array), `app/api/auth/instagram/callback/route.ts`, `SPIKE-RESULTS.md` §1a, `docs/HANDOVER.md` §4.
NECESSITY	Not necessary for production — Facebook Login is the chosen, working production auth path.
DEPENDENCIES IF REMOVED	Shipped MVP unaffected. The dev-only Instagram Login option would be unable to request Advanced Access later without re-adding it.

02 `instagram_business_manage_messages` — REMOVE

Instagram Login only

PURPOSE	Per Meta's current permission reference (fetched live for this audit): "access messages on Instagram professional account." A bundled Instagram-Login-track scope requested at connect time.
AUTH PATH	Instagram Login only.
STATUS	`CONFIRMED` Requested and reportedly granted (`SPIKE-RESULTS.md` §1a lists it under "Permissions granted") but **zero functionality uses it** — exhaustive repo search for messaging/DM/conversation code returned no matches anywhere in `app/` or `lib/`.
API DEPENDENCY	None called. Would be the Instagram Messaging API's conversation/message endpoints.
EVIDENCE	`app/api/auth/instagram/start/route.ts` SCOPES array; `SPIKE-RESULTS.md` §1a; repo-wide grep for messaging code (no matches beyond unrelated UI/error-message strings).
NECESSITY	Not necessary — no messaging feature exists anywhere in Grafeat's stated scope; `docs/DECISIONS.md` never mentions messaging as even a future feature.
DEPENDENCIES IF REMOVED	None. Nothing depends on this.

REMOVED

03 pages_show_list

KEEP

Facebook Login for Business only

PURPOSE	Lists the Facebook Pages the organizer manages (`GET /me/accounts`) — the first step in resolving which Instagram professional account is linked to which Page.
AUTH PATH	Facebook Login for Business only.
STATUS	CONFIRMED Implemented and tested. Confirmed granted and exercised live (`SPIKE-RESULTS.md` §1b), and independently reconfirmed via a direct live `/me/permissions` check during this QA pass (2026-10-30).
API DEPENDENCY	`GET /me/accounts?fields=id,name,category,tasks` — `app/api/auth/facebook/callback/route.ts` .
EVIDENCE	`app/api/auth/facebook/callback/route.ts` ; `app/api/auth/facebook/start/route.ts` 's Configuration comment; `SPIKE-RESULTS.md` §1b; this session's live permission check.
NECESSITY	Essential — the one-time organizer-connect flow's core account-resolution step.
DEPENDENCIES IF REMOVED	Breaks the entire Facebook Login connect flow — no organizer could connect at all.

04 instagram_business_content_publish

DEFER

Instagram Login only

PURPOSE	Per Meta's reference: "create organic feed photo and video posts." The Instagram-Login-track publish permission — would back a future carousel-publishing feature.
AUTH PATH	Instagram Login only (Facebook-Login sibling is #7).
STATUS	CONFIRMED Requested & reportedly granted (`SPIKE-RESULTS.md` §1a) but entirely unused. DECISION Carousel generation/publishing is explicitly "[FUTURE — no schema, no code]" per `docs/DECISIONS.md` . The only "carousel" code anywhere in the repo is the landing-page marketing demo (`app/landing/curator/*`), explicitly flagged in `docs/HANDOVER.md` §1 as "not reusable backend infrastructure, despite looking finished."

API DEPENDENCY	None implemented. Would be `POST /{ig-user-id}/media` + `/media_publish` — never called.
EVIDENCE	`app/api/auth/instagram/start/route.ts` ; `SPIKE-RESULTS.md` §1a; `docs/DECISIONS.md` ; `app/landing/curator/*` (demo-only).
NECESSITY	Not necessary for the current MVP as scoped (connect, discover, review/curate — explicitly not publish).
DEPENDENCIES IF REMOVED	None now. Becomes necessary only once carousel publishing is actually built with a real, demonstrable flow — and at that point the production-track sibling (#7) is the one that will actually matter, not this one.

05 `instagram_manage_comments`

KEEP — HIGHEST PRIORITY AFTER #14

Facebook Login for Business only

PURPOSE	Per Meta's reference: "create, delete and hide comments." In practice Grafeat uses only its **read/lookup-gating** side — it is one of the three permissions `mentioned_media` requires (confirmed on Meta's own reference page, fetched live for this audit), the exact mechanism that verifies a genuine organizer mention. Its write capabilities (actually creating/deleting/hiding a comment) are never exercised by any Grafeat code.
AUTH PATH	Facebook Login for Business only.
STATUS	CONFIRMED Implemented and tested — the single most load-bearing permission on this list. Confirmed working live twice: the spike's 2026-10-20 `mentioned_media` test (full field set returned) and this project's Experiment 11 (`docs/meta-api-experiments.md` , 2026-10-27), which also discovered Meta's undocumented "not mentioned" HTTP-400 behavior, now handled with a dedicated classifier and regression tests.
API DEPENDENCY	`GET /{ig-user-id}?fields=mentioned_media.media_id({media_id}){username,caption,media_type,media_url,thumbnail_url,permalink}` — `lib/meta-graph.ts` 's `fetchMentionedMedia` , called by `lib/processing.ts` for every pending candidate.
EVIDENCE	`lib/meta-graph.ts` , `lib/processing.ts` , `tests/meta-graph.test.ts` , `tests/processing.test.ts` , `docs/meta-api-experiments.md` Experiment 11, `SPIKE-RESULTS.md` §3.1.
NECESSITY	Essential — without it Grafeat cannot distinguish a genuine organizer mention from a hashtag-only post. The curation value proposition depends on this directly.

DEPENDENCIES IF REMOVED	Breaks mention verification entirely — the entire curation pipeline collapses. *Submission note: justify narrowly as read/lookup usage — don't claim or demo comment creation/moderation, which isn't implemented.*

06 `instagram_manage_contents` — REMOVE

Not independently confirmed — see flag below

PURPOSE	Confirmed directly from Meta's live permission reference (fetched during this audit): "delete posts on behalf of Instagram account" — a content-deletion permission. Not found anywhere in this project's history before this audit.
AUTH PATH	FLAG Likely Facebook-Login-track by naming pattern, but not independently confirmed from a dedicated reference sub-page in this session — verify directly in the dashboard.
STATUS	CONFIRMED Not requested, not implemented, not planned. Exhaustive repo-wide search (code, docs, prompts, research notes) returned zero matches for this exact permission name.
API DEPENDENCY	None — would be a post-deletion endpoint on the organizer's own media. Grafeat has no feature that deletes organizer content.
EVIDENCE	Repo-wide grep (no matches); live Meta permission reference fetch (this audit) confirming the permission's existence and description.
NECESSITY	Not necessary — no Grafeat feature deletes organizer content, now or planned.
DEPENDENCIES IF REMOVED	None. *If this appears on your screen, it most likely came from a bundled Meta use-case template, not a deliberate request — see the note under "Permissions automatically introduced by use cases" in §F.*

07 `instagram_content_publish` — DEFER

Facebook Login for Business only

PURPOSE	Facebook-Login-track sibling of #4 — "create organic feed photo and video posts." The production-track publish permission, for when carousel publishing is eventually built.
AUTH PATH	Facebook Login for Business only.
STATUS	CONFIRMED Identified as available during the spike (`SPIKE-RESULTS.md` §1b's "content management" permission set) but **deliberately left unchecked** ("...deliberately left `business_management`, `instagram_content_publish`...

`business_management` , `instagram_content_publish` , `instagram_manage_messages` unchecked as not needed for discovery"). Not currently granted — confirmed via live `/me/permissions` check, which lists only 6 permissions, none of them this one. No carousel/publish code exists anywhere in the real app.

API DEPENDENCY — None implemented. Would be `POST /{ig-user-id}/media` + `/media_publish` .

EVIDENCE — `SPIKE-RESULTS.md` §1b points 7–8; `docs/DECISIONS.md` ; live permissions check (this QA pass).

NECESSITY — Not necessary for the current MVP (same reasoning as #4).

DEPENDENCIES IF REMOVED — None now. Becomes necessary alongside building a real publish flow — and since Facebook Login is the production auth path, **this is the permission that will actually matter** when that day comes, not #4.

---

08 `business_management` — KEEP

Facebook Login for Business only

PURPOSE — Grants access to Business Portfolio data (`/me/businesses` , `/{business-id}/owned_pages` , `/client_pages`) — a fallback for resolving an organizer's Page→Instagram link when the Page isn't directly visible via `/me/accounts` (e.g. owned by a different Business Portfolio than the one managing the Grafeat app).

AUTH PATH — Facebook Login for Business only.

STATUS — CONFIRMED Implemented, granted, present in code. **Not yet proven necessary in practice** — for @the_calligrail specifically, this fallback was *not* what fixed the real connection issue (the actual fix was picking the correct Business Portfolio in the OAuth consent screen itself); the fallback code path has not yet been the deciding factor for any organizer tested so far.

API DEPENDENCY — `GET /me/businesses` , `GET /{business-id}/owned_pages` , `GET /{business-id}/client_pages` — `app/api/auth/facebook/callback/route.ts` .

EVIDENCE — `app/api/auth/facebook/callback/route.ts` ; `SPIKE-RESULTS.md` §1b "Root cause of the empty-pages mystery"; live permissions check confirming it's granted.

NECESSITY — Likely necessary for the stated MVP constraint — "connecting *independent* challenge organizers" implies varied account structures. Different real organizers will plausibly have Pages under Business

	Portfolios not returned directly by `/me/accounts`, exactly the scenario this exists for.
DEPENDENCIES IF REMOVED	Wouldn't break @the_calligrail's existing connection, but removes the only fallback for an organizer whose Page sits under an unexpected Business Portfolio — a real, plausible failure mode for the stated "independent organizers" MVP goal.

09 `instagram_manage_messages` — REMOVE

Facebook Login for Business only

PURPOSE	Per Meta's reference: "read and respond to Instagram Direct messages" — the Facebook-Login-track messaging permission.
AUTH PATH	Facebook Login for Business only.
STATUS	CONFIRMED Identified as available during the spike's guided setup flow ("messaging" permission set, `SPIKE-RESULTS.md` §1b point 7) but never selected. Not granted (live check confirms). No DM/messaging code anywhere in the app.
API DEPENDENCY	None implemented.
EVIDENCE	`SPIKE-RESULTS.md` §1b point 7; live permissions check; repo-wide grep (no matches).
NECESSITY	Not necessary — no messaging feature exists or is planned anywhere in Grafeat's scope.
DEPENDENCIES IF REMOVED	None.

10 `instagram_business_manage_comments` — DEFER

Instagram Login only

PURPOSE	Instagram-Login-track sibling of #5 — per Meta's reference, "manage Instagram comments." Required for Instagram Login's `/tags` and `mentions` -reply workflow.
AUTH PATH	Instagram Login only.
STATUS	CONFIRMED Requested & reportedly granted (`SPIKE-RESULTS.md` §1a) but Instagram Login isn't used in production (same status as #1). FLAG `SPIKE-RESULTS.md` §1b also records an internal Meta-dashboard inconsistency — this permission showed granted on the OAuth consent screen but "not granted" in the Permissions-and-

	Features catalog at the time of that spike. Not something this codebase can resolve; verify current state directly.
API DEPENDENCY	Would back `/tags` polling and `POST /mentions` replies — neither called by production code.
EVIDENCE	`app/api/auth/instagram/start/route.ts` ; `SPIKE-RESULTS.md` §1a/§1b; `docs/HANDOVER.md` §4.
NECESSITY	Not necessary for the production MVP (Instagram Login isn't the shipped auth path).
DEPENDENCIES IF REMOVED	None for the shipped MVP.

11 `pages_read_engagement` KEEP

Facebook Login for Business only

PURPOSE	Required (alongside `instagram_basic` and `instagram_manage_comments`) for the `mentioned_media` lookup — confirmed directly on Meta's own reference page, fetched live for this audit.
AUTH PATH	Facebook Login for Business only.
STATUS	CONFIRMED Implemented and tested — same evidence trail as #5, since it's a co-requirement of the identical working, tested call.
API DEPENDENCY	Same as #5 — `GET /{ig-user-id}?fields=mentioned_media...` .
EVIDENCE	Same as #5; also `app/api/auth/facebook/start/route.ts` 's Configuration comment and `tests/meta-graph.test.ts` .
NECESSITY	Essential — co-required with #5 for mention verification.
DEPENDENCIES IF REMOVED	Same as removing #5 — breaks mention verification.

12 `public_profile` KEEP

Facebook Login (bundled by default)

PURPOSE	Default base identity permission (name/profile picture) bundled with virtually any Facebook Login flow — not independently toggleable in most Facebook Login for Business configurations.
AUTH PATH	Facebook Login for Business (implicitly present in nearly every Facebook OAuth flow).

STATUS	CONFIRMED Implemented and tested — confirmed granted (`SPIKE-RESULTS.md` §1b; live permissions check this session).
API DEPENDENCY	None called explicitly by Grafeat's own code — a byproduct of the login flow, not a capability Grafeat deliberately exercises.
EVIDENCE	`SPIKE-RESULTS.md` §1b; live permissions check.
NECESSITY	Necessary in the trivial sense that Facebook Login for Business bundles it automatically.
DEPENDENCIES IF REMOVED	Would likely break the OAuth handshake itself. FLAG Verify whether it's even separately listed/removable on your specific App Review screen — it's usually auto-included, not a discretionary request.

13 `instagram_basic`

KEEP

Facebook Login for Business only

PURPOSE	Per Meta's reference: "read an Instagram account profile's info and media" — the Facebook-Login-track base permission. Co-required for nearly everything: Page→Instagram resolution, hashtag search, and `mentioned_media` lookup all list it as a baseline requirement.
AUTH PATH	Facebook Login for Business only.
STATUS	CONFIRMED Implemented and tested — the most broadly-depended-upon permission on this list; confirmed granted and exercised across every working Facebook-Login-path call in this project.
API DEPENDENCY	Baseline requirement for `ig_hashtag_search` , `/{hashtag-id}/recent_media` , and `mentioned_media` — effectively every call `lib/meta-graph.ts` makes.
EVIDENCE	`lib/meta-graph.ts` (every method); `SPIKE-RESULTS.md` §1b/§3.1; `docs/meta-api-experiments.md` Experiment 11; live permissions check.
NECESSITY	Essential — the base permission underneath the entire discovery/verification pipeline.
DEPENDENCIES IF REMOVED	Breaks everything — discovery, mention verification, the whole pipeline.

14 `Instagram Public Content Access`

KEEP — TOP PRIORITY

Facebook Login for Business only — Feature, not a permission

PURPOSE	The Meta **Feature** (not a permission) gating the three hashtag-based endpoints — `ig_hashtag_search`, `{hashtag-id}/recent_media`, `{hashtag-id}/top_media`. This is the mechanism behind Grafeat's entire discovery concept.
AUTH PATH	Facebook Login for Business only — no Instagram Login equivalent exists for hashtag search anywhere in Meta's documented surface (confirmed via this project's own `research_notes/meta_discovery_mechanisms.md`).
STATUS	**FLAG — UNRESOLVED CONTRADICTION, RESOLVE BEFORE SUBMITTING** `SPIKE-RESULTS.md` (2026-10-19/20) recorded an explicit, named HTTP 400 rejection: *"To use 'Instagram Public Content Access', your use of this endpoint must be reviewed and approved by Facebook."* Seven days later, Experiment 11 (`docs/meta-api-experiments.md`, 2026-10-27) ran the identical call against the same connection and hashtag and it succeeded cleanly — and it has kept working since, including in this session's own investigation. Nothing in this repository shows App Review being completed between those dates. The most consistent explanation (matching this project's own repeatedly-corroborated Standard-vs-Advanced pattern, also seen with webhooks): Standard Access covers the app's own role-holder/Tester-held connected accounts, but this has never been tested against an arbitrary external organizer with no role on the app — exactly what production requires.
API DEPENDENCY	`GET ig_hashtag_search?user_id=...&q=...`, `GET /{hashtag-id}/recent_media?...` — `lib/meta-graph.ts`, called every sync by `lib/discovery.ts`.
EVIDENCE	`SPIKE-RESULTS.md` §3.1 Test E (the rejection); `docs/meta-api-experiments.md` Experiments 8, 9, 11 (later successes); `docs/HANDOVER.md` §10/§14 and `docs/DECISIONS.md` ("External-organizer Advanced Access remains unverified" — an open risk this project already flags independently of this audit); `research_notes/access_requirements_and_hashtag_feasibility.md`.
NECESSITY	Essential — the core of Grafeat's value proposition. Without it there is no discovery mechanism at all for new, unknown submissions.
DEPENDENCIES IF REMOVED	Eliminates discovery entirely — no way to find a new challenge submission without the organizer manually reporting it. *Best-positioned item for approval: hashtag-based contest/entrant discovery is within Meta's documented allowed-use category, and five independent commercial precedents (Easypromos, Woobox, ShortStack, Gleam, Brandwatch) operate the identical pattern successfully (`research_notes/commercial_precedent.md`).*

B. Recommended minimum App Review permission set

Seven permissions, all on the Facebook Login for Business track. Zero Instagram-Login-track permissions are needed for the production MVP as architected today.

PERMISSION	WHY IT'S IN THE MINIMUM SET
`pages_show_list`	Organizer connect flow — resolves the linked Page.
`instagram_basic`	Base requirement under every working Facebook-Login-path call.
`instagram_manage_comments`	Co-required for mention verification (read/lookup usage only).
`pages_read_engagement`	Co-required for mention verification.
`business_management`	Fallback Page resolution for organizers under non-obvious Business Portfolios.
`public_profile`	Bundled automatically with Facebook Login; required for the OAuth handshake itself.
Instagram Public Content Access	The entire hashtag-discovery mechanism — Grafeat's core function.

C. Permissions to defer until future releases

PERMISSION	DEFER UNTIL…
`instagram_business_basic`	Instagram Login ever becomes the production auth path (currently dev-only).
`instagram_business_manage_comments`	Same — Instagram-Login-track mention/comment lookup, unused in production.
`instagram_content_publish`	Carousel publishing is actually built with a real, demonstrable flow. This is the production-track permission for that future feature.
`instagram_business_content_publish`	Same trigger as above, but only relevant if Instagram Login also becomes production — lower priority than its Facebook-Login sibling.

Not deferred but actively **not recommended at all**, with no plausible future trigger identified: `instagram_manage_contents` (post-deletion — no Grafeat feature deletes organizer posts), `instagram_manage_messages` and `instagram_business_manage_messages` (messaging — no Grafeat feature sends/reads DMs, and none is planned per `docs/DECISIONS.md`).

no Grafeat feature sends/reads DMs, and none is planned per `docs/DECISIONS.md`).

D. Missing permissions for the intended architecture

None identified. The stated MVP — connect, discover, review/curate, prepare carousels with attribution — is fully covered by the 7-item minimum set in §B, with one clarification worth stating explicitly for the submission:

> **"Preparing" a carousel needs no additional permission.** Composing a layout and attribution caption from already-discovered media (whose URL and creator metadata were already retrieved via `mentioned_media`, already covered by the KEEP set) is pure Grafeat-side logic — no additional Meta scope is required merely to assemble a carousel. A new permission (`instagram_content_publish`, already in the defer list) is only needed at the moment of actually *publishing* it to Instagram — which is explicitly out of scope for this MVP per `docs/DECISIONS.md`.

E. Functionality to complete before reviewers can test the requested permissions

1. **Deploy to a stable production domain.** `docs/HANDOVER.md` §13 confirms: "Not deployed to Vercel for this slice." Meta reviewers need a live, reviewer-accessible URL — not localhost. This is a hard prerequisite for every permission below, not just a nice-to-have.
2. **Confirm the three legal/compliance pages are registered in the App Dashboard.** `META-SETUP.md` lists Privacy Policy, Terms of Use, and Data Deletion URLs as required under App Settings → Basic — the pages exist (`app/privacy`, `app/terms`, `app/data-deletion`) but the setup checklist's own checkboxes were never marked complete. Verify actual registration, not just page existence.
3. **A demonstrable organizer-connect screencast** (for `pages_show_list`, `business_management`, `public_profile`, `instagram_basic`) — the flow is fully built; ready once deployed.
4. **A demonstrable "verified genuine mention" moment** (for `instagram_manage_comments`, `pages_read_engagement`) — the Slice B gallery UI, showing a real discovered-and-verified submission with creator attribution, is exactly this demo. Ready once a live, currently-discoverable test post exists at recording time.
5. **A clean, repeatable, end-to-end discovery demo** (for Instagram Public Content Access) — organizer creates a challenge → participant publishes a public hashtag post → Grafeat discovers it automatically on the next sync. Fully built, but this QA cycle's own investigation found the hashtag-discovery result can unexpectedly return zero posts for reasons not yet conclusively explained (see `docs/meta-api-experiments.md` Experiment 12) — resolve that reliability question before recording, so the demo doesn't fail live or need an unexplained retry.

F. Uncertainties requiring direct Meta documentation / dashboard verification

1. **The Instagram Public Content Access contradiction** (blocked 2026-10-19, working 2026-10-27 onward, same app and connection) — needs direct confirmation from the Meta App Dashboard of this app's exact current Access Level/App Review status for this feature. Cannot be resolved from the codebase alone.
2. **`instagram_manage_contents` 's exact auth-path mapping** — confirmed to exist and its description, but this audit's live fetch didn't yield the same clean per-login-path breakdown it got for the other permissions. Worth a direct dashboard check.
3. **Whether `public_profile` is separately listed/removable on your specific App Review screen**, or auto-bundled — Meta's behavior varies by app/configuration type.
4. **Whether Advanced Access already working for the organizer's own test account extends automatically to arbitrary external production organizers**, or needs a separate confirmation — this is the single biggest open risk this project's own docs (`docs/HANDOVER.md` §10/§14, `docs/DECISIONS.md`) have already flagged repeatedly, independent of this audit, and it remains unresolved.
5. **Permissions automatically introduced by Meta use cases.** If permissions like `instagram_manage_contents` appear on your review screen without this project ever having deliberately requested them, the likely cause is a bundled Meta "use case" template pulling in a broader scope set than the app's actual Configuration — worth checking which "use case" is attached to the app in the Dashboard and whether it can be narrowed before submission.